



Habib University - City Campus

Course Title: EE-426/CE-442 Cryptography and Network Security

Instructor's name: Dr. Farhan Khan

Class ID: 1010

Examination: Final - Term (Fall 2023) **SOLUTION** Exam Date: 14/12/2023

Total Marks: 100

Time/ Duration: 4:30pm - 7:00pm

Instructions for students:

- Laptops allowed during first 1.5 hour of the exam to solve complex modular arithmetic operations using dcode.fr website only.
- Any other type of electronic gadget like smartphone is prohibited to use during the exam.
- The question paper must be returned at the end of exam along with answer script.
- All answers must be given on answer script.

CLO Assessment: This exam assesses students for the following course learning outcomes.

Course Learning Outcomes		CLO Assessed
CLO 1	Apply the concepts from number theory and algebraic structures in understanding the design of cryptographic algorithms.	
CLO 2	Evaluate the suitability of message integrity, message authentication, and key management methods when applying in a given security scenario.	✓
CLO 3	Explain the setup, algorithms, and security issues in existing symmetric-key and asymmetric-key cryptosystems.	
CLO 4	Apply cryptography-based network security technologies in the design of networked information systems.	✓

Part 1 covers CLO 2 [50 points] Learning Domain Level Mapping: Cog-4

Question 1a [10 points]:

Using the RSA scheme, let $p = 809$, $q = 751$, and $d = 23$. Calculate the public key e . Then:

- Sign and verify a message with $M_1 = 5$. Call the signature S_1 .
- Sign and verify a message with $M_2 = 10$. Call the signature S_2 .
- Show that if $M = M_1 \times M_2 = 50$, then $S = S_1 \times S_2$.
- For the same value of p , which digital signature scheme will you choose if you require a digital signature computation which is faster than RSA signature computation.

Answer:

Values of p and q are given in the question,

$$n = p \times q = 809 \times 751 = 607559$$

$$\phi(n) = (p-1) \times (q-1) = (809-1) \times (751-1) = 606000.$$

Since $d = 23$, we have $e = d^{-1} \bmod \phi(n) = 158087$

(i)

$$S_1 = M_1^d \bmod n = 5^{23} \bmod 607559 = 186465$$

$$M_1 = S_1^e \bmod n = 186465^{158087} \bmod 607559 = 5$$

(ii)

$$S_2 = M_2^d \bmod n = 10^{23} \bmod 607559 = 488214$$

$$M_1 = S_2^e \bmod n = 488214^{158087} \bmod 607559 = \mathbf{10}$$

(iii)

If $M = M_1 \times M_2 = 50$, then we have:

$$S = M^d \bmod n = 50^{23} \bmod 607559 = \mathbf{5627}$$

$$S = (S_1 \times S_2) \bmod n = (186465 \times 488214) \bmod 607559 = 91034823510 \bmod 607559 = \mathbf{5627}$$

(iv)

DSS will be faster than RSA signature computation.

Question 1b [10 points]:

Using the ElGamal scheme, let $p = 881$ and $d = 700$. Public key consists of values of p , e_1 and e_2 . Choose $r = 17$. Then:

- i. Find the values of e_1 and e_2 .
- ii. Find the value of S_1 and S_2 if $M = 40$.
- iii. Verify the signature by showing that V_1 is congruent to V_2 .
- iv. For the same value of p , which digital signature scheme will you choose if you require a digital signature size which is smaller than ElGamal signature.

Answer:

Values of p and d are given in the question,
 $p = 881$ $d = 700$.

(i)

We choose $e_1 = 3$ (primitive root of 881).

$$\text{Then } e_2 = e_1^d \bmod p = 471.$$

$$r = 17$$

(ii)

$$S_1 = e_1^r \bmod p = 3^{17} \bmod 881 = \mathbf{540}$$

$$S_2 = (M - d \times S_1) r^{-1} \bmod (p-1) = (40 - 700 \times 540) 17^{-1} \bmod 880 = (40 - 700 \times 540) 17^{-1} \bmod 880 = 440 \times 673 \bmod 880 = \mathbf{440}$$

$$\text{where } 17^{-1} \bmod 880 = 673$$

(iii)

Verification:

We can verify the signature because V_1 is congruent to V_2 .

$$V_1 = e_1^M \bmod p = 3^{40} \bmod 881 = \mathbf{791}$$

$$V_2 = e_2^{S_1} \times S_1^{S_2} \bmod p = 471^{540} \times 540^{440} \bmod 881 = 90 \times 880 \bmod 881 = \mathbf{791}$$

(iv)

DSS will generate a smaller signature because q is less than p .

Question 1c [5 points]:

In the Diffie-Hellman protocol, what happens if x and y have the same value, that is, Alice and Bob have accidentally chosen the same number? Are R_1 and R_2 the same? Do the session keys calculated by Alice and Bob have the same value? Use the following values to prove your claim.

$g = 7$, $p = 23$, $x = 5$, and $y = 5$.

Answer:

Assume that both Alice and Bob choose x (instead of x and y). Then we have:

$$R_1 = g^x \bmod p$$

$$K = (g^x \bmod p)^x \bmod p = g^{x \cdot x} \bmod p$$

$$R_2 = g^x \bmod p$$

$$K = (g^x \bmod p)^x \bmod p = g^{x \cdot x} \bmod p$$

Both R_1 and R_2 are the same and the K is the same. For example, if we use $g = 7$ and $p = 23$, and $x = 5$, we get $R_1 = R_2 = 17$ and $K = 21$.

Question 1d [5 points]:

The station-to-station protocol is a method based on Diffie-Hellman key exchange. It uses digital signatures with public-key certificates to establish a session key between Alice and Bob, as shown in Figure 1.

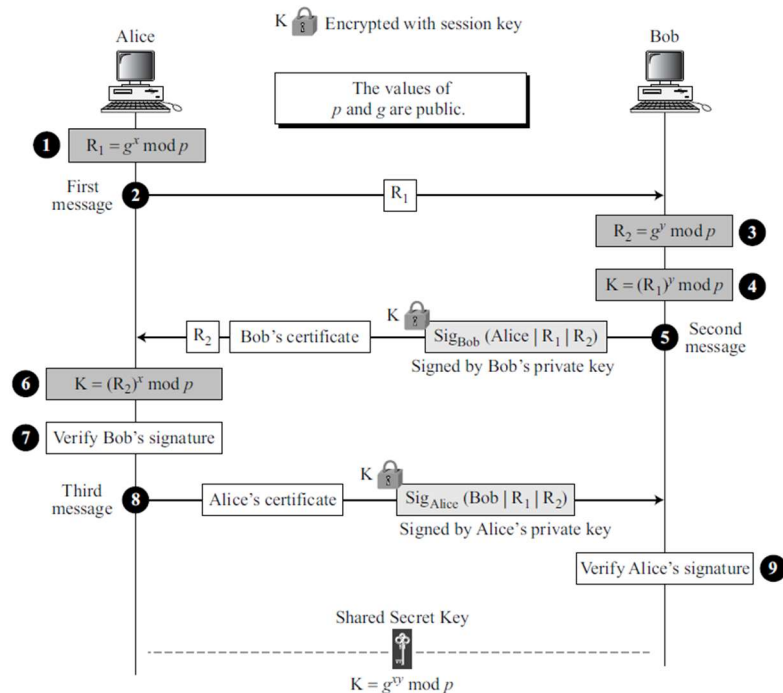


Figure 1.

In station-to-station protocol, show that if the identity of the receiver is removed from the signature, the protocol becomes vulnerable to man-in-the-middle attack.

Answer:

A simple view of this attack can be described as follows (see Figure 1 in the question):

- Eve intercepts the message sent in step 2, discards the message, and sends a new message with the same value of R_1 to Bob.

- b. Bob receives the message, and judging by the sender address of the packet, he believes that the message is originated from Eve.
- c. Bob, calculates R_2 and K and sends them, in step 5, to Eve (the sender of the message in step 2).
- d. Eve intercepts the message and resends it to Alice pretending that it is coming from Bob (false sender address).
- e. Alice calculates the session key and sends the message in step 8 to Bob.
- f. Bob receives the message in step 8 and he knows that it is coming from Alice (sender address). Bob discards this message because he does not expect this message to come from Alice; he is waiting to receive a message from Eve, which never happens.
- g. The result is that Alice believes that a session key is established between herself and Bob; Bob believes that the session with Eve is broken.

Question 2a [10 points]

Figure 2 shows that the CA (the root) has signed certificates for CA1, CA2, and CA3; CA1 has signed certificates for User1, User2, and User3; and so on.

- i. Show how User3, knowing only the public key of the Root1 (the root), can obtain a verified copy of User6's public key.

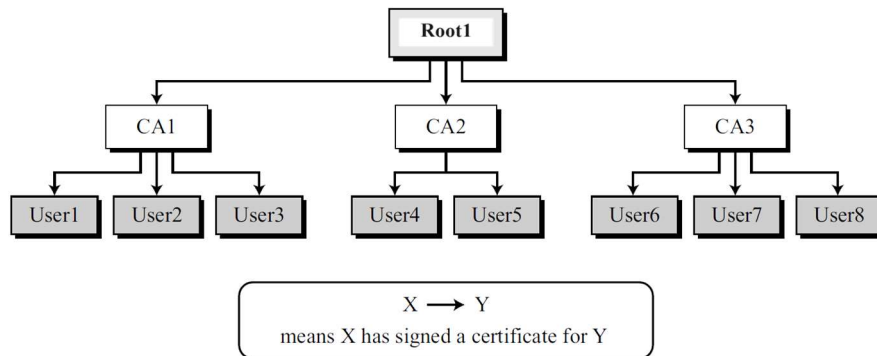


Figure 2.

- ii. Figure 3 shows the mesh structure connecting only roots together; each root has its own hierarchical structure, shown by a triangle. User1 is under the authority of Root1; User9 is under the authority of Root2. Show how User1 can obtain User9's verified public key.

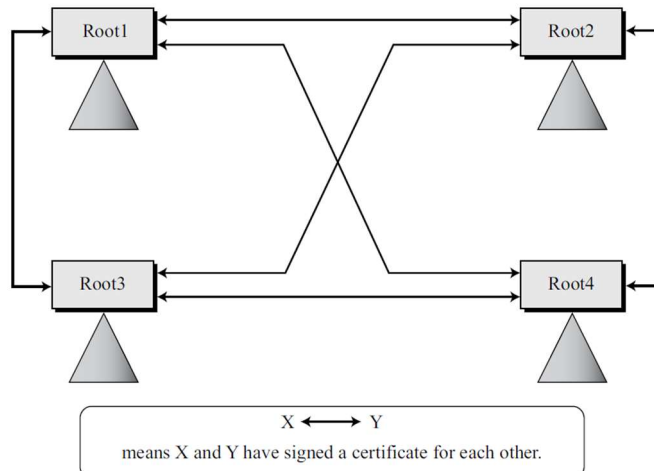


Figure 3.

Answer:

(i)

User6 sends a chain of certificates, $\text{Root1} \ll \text{CA3} \gg$ and $\text{CA3} \ll \text{User6} \gg$, to User3.

- a. User3 validates $\text{Root1} \ll \text{CA3} \gg$ using the public key of Root1.
- b. User3 extracts the public key of CA3 from $\text{Root1} \ll \text{CA3} \gg$.

- c. User3 validates CA3<<User6>> using the public key of CA3.
- d. User3 extracts the public key of User 6 from CA3<<User6>>.

(ii)

User9 sends a chain of certificates from Root2 to User1. User1 looks at the directory of Root1 to find Root1<<Root1>> and Root1<<Root2>> certificates. Using the following process, User1 can verify User9's public key.

- a. User1 validates Root1<<Root2>> using the public key of Root1.
- b. User1 extracts the public key of Root2 from Root1<<Root2>>.
- c. User1 validates Root2<<User9>> using the public key of Root2.
- d. User1 extracts the public key of User 9 from Root2<<User9>>.

Question 2b [5 points]

For $p = 569$, $q = 683$, and $s = 157$, show five rounds of the Fiat-Shamir protocol by calculating the values and filling in the entries of the following table.

Hint: The values of the last two columns should be the same if Claimant is honest or has correctly guessed the value of c .

r	$x \leftarrow r^2 \bmod n$	C	$y \leftarrow rs^c \bmod n$	$y^2 \bmod n$	$xv^c \bmod n$
1		0			
2		1			
4		0			
8		1			
16		0			

Answer:

Values given in the question can be used to calculate n and v :

$$p = 569, q = 683, n = p \times q = 388267, s = 157, v = s^2 \bmod n = 24649$$

r	$x \leftarrow r^2 \bmod n$	C	$y \leftarrow rs^c \bmod n$	$y^2 \bmod n$	$xv^c \bmod n$
1	1	0	1	1	1
2	4	1	314	98596	98596
4	16	0	4	16	16
8	64	1	1256	24468	24468
16	256	0	16	256	256

Question 2c [5 points]

Using the DSS scheme, let $q = 59$, $p = 709$, and $d = 14$. Find values for e_1 and e_2 . Choose $r = 13$.

- i. Find the value of S_1 and S_2 if $h(M) = 10$.
- ii. Verify the signature.

Answer:

Values given in the question: $q = 59$, $p = 709$, $d = 14$, $r = 13$ and $h(M) = 10$.

We choose $e_0 = 2$ (primitive element in $\mathbb{Z}_p$).

Then we have $e_1 = e_0^{(p-1)/q} \bmod p = 551$

$e_2 = e_1^d \bmod p = 399$.

(i)

The following shows the calculation for S_1 and S_2 at the sender site and the calculation of V at the receiver site.

$$S_1 = (e_1^r \bmod p) \bmod q = 48$$

$$S_2 = (h(M) + d \times S_1) r^{-1} \bmod q = ((10 + 14 \times 48) \times 50) \bmod 59 = 57$$

(ii)

Verification:

$S_1 = 48$ as computed earlier.

$$S_2^{-1} \bmod q = 29$$

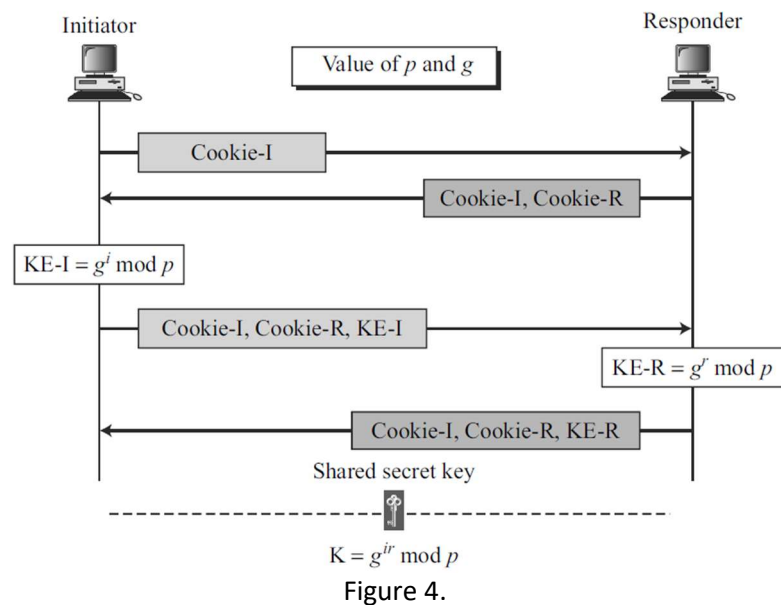
$$V = (e_1^{h(M)} \times 29 \times e_2^{S_1 \times 29} \bmod p) \bmod q = (400 \times 662 \bmod p) \bmod q = 343 \bmod q = 48$$

Part 2 covers CLO 4 [50 points] Learning Domain Level Mapping: Cog-3

Question 3a [10 points]

Figure 4 shows improved Diffie-Hellman key exchange process with Cookies used in IPSec. Briefly explain the following:

- How does the improved DH process prevent clogging/denial-of-service attack?
- How does the improved DH process prevent replay attack?



Answer:

(i)

To prevent the clogging attack, we can add two extra messages to the protocol to force the two parties to send cookies. Figure 4 shows the refinement that can prevent a clogging attack. The cookie is the result of hashing a unique identifier of the peer (such as IP address, port number, and protocol), a secret random number known to the party that generates the cookie, and a timestamp.

The initiator sends its own cookie; the responder its own. Both cookies are repeated, unchanged, in every following message. The calculations of half-keys and the session key are postponed until the cookies are returned. If any of the peers is a hacker attempting a clogging attack, the cookies are not returned; the corresponding party does not spend the time and effort to calculate the half-key or the session key. For example, if the initiator is a hacker using a bogus IP address, the initiator does not receive the second message and cannot send the third message. The process is aborted.

(ii)

The information from one session can be replayed in a future session by a malicious intruder. To prevent this, we can add nonces to the third and fourth messages to preserve the freshness of the message.

Question 3b [10 points]

The following two scenarios are related to replay attack protection in IPSec using replay window:

- i. Suppose host A receives an authenticated packet with the sequence number 181. The replay window spans from 200 to 263. What will host A do with the packet? What is the window span after this event?
- ii. Suppose host B receives an authenticated packet with the sequence number 208. The replay window spans from 200 to 263. What will host B do with the packet? What is the window span after this event?

Answer:

(i)

Since the sequence number of the packet (181) is out of the window (200 to 264), the packet is discarded. It is either duplicate or its arrival time has expired. The window span does not change.

(ii)

The sequence number of the packet (208) is inside the window (200 to 263). If the packet is new (the corresponding slot is not marked), the packet is accepted and the corresponding slot is marked. If the corresponding slot is marked, the packet is a duplicate packet; it is discarded. There is no change in the window span in either case.

Question 3c [10 points]

- i. Your company has two security gateways and it wants to operate a tunnel to authenticate all traffic between the networks they connect together. The main advantage to using tunnel mode, is that tunnel mode totally protects the encapsulated IP datagram. If the company does not want the overhead involved in encryption, which IPSec protocol will you recommend and why?
- ii. Your company uses frame relay to connect head office and a remote branch in Thar desert, but they want to explore other options for transmitting internal confidential data that are less expensive, more secure, and globally accessible. By exploiting the Internet, you can easily establish a virtual private network (VPN) to meet the needs of your company. Your company and its branch office both require VPN protection across the Internet, but not within their respective intranets. Because you consider the intranets trusted, the best solution is to create a site-to-site VPN using IPSec. Which IPSec protocol would you recommend (AH or ESP) for creating the site-to-site VPN and why?

Answer:

(i)

I would recommend use of AH(authentication header) protocol of IPSec as this will allow the security gateways to authenticate each and every packet without the additional overhead of encryption as AH does not provide encryption.

(ii)

For the given scenario of creating a site-to-site VPN, the ESP (Encapsulating Security Payload) protocol of IPSec is more commonly recommended than the AH (Authentication Header) protocol. Some reasons why ESP is preferred is that it provides encryption along with authentication, widespread support, and full traffic flow confidentiality.

Question 3d [10 points]

- i. Figure 5 shows Outbound Security Association processing in the form of a flowchart. Using the flowchart, explain what will happen if a packet needs to be sent out securely but there is no Security Association established for it yet.

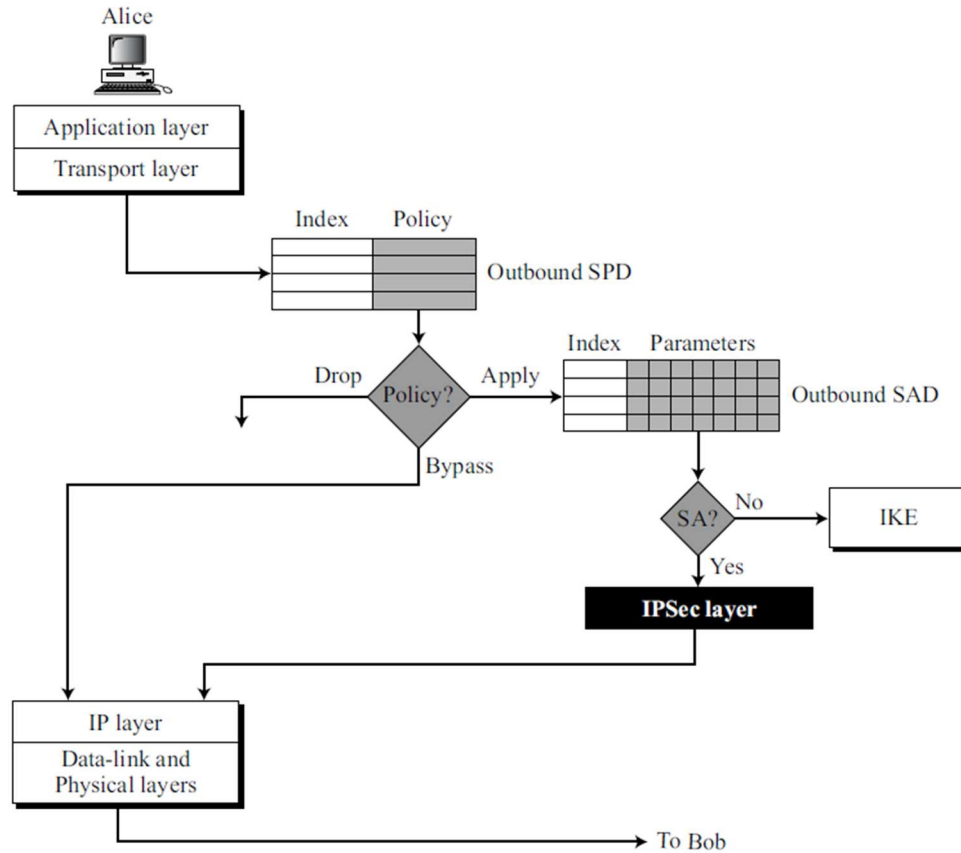


Figure 5.

- ii. Figure 6 shows Inbound Security Association processing in the form of a flowchart. Using the flowchart, explain what will happen if a packet is received and there is an inbound Security Association already established for it.

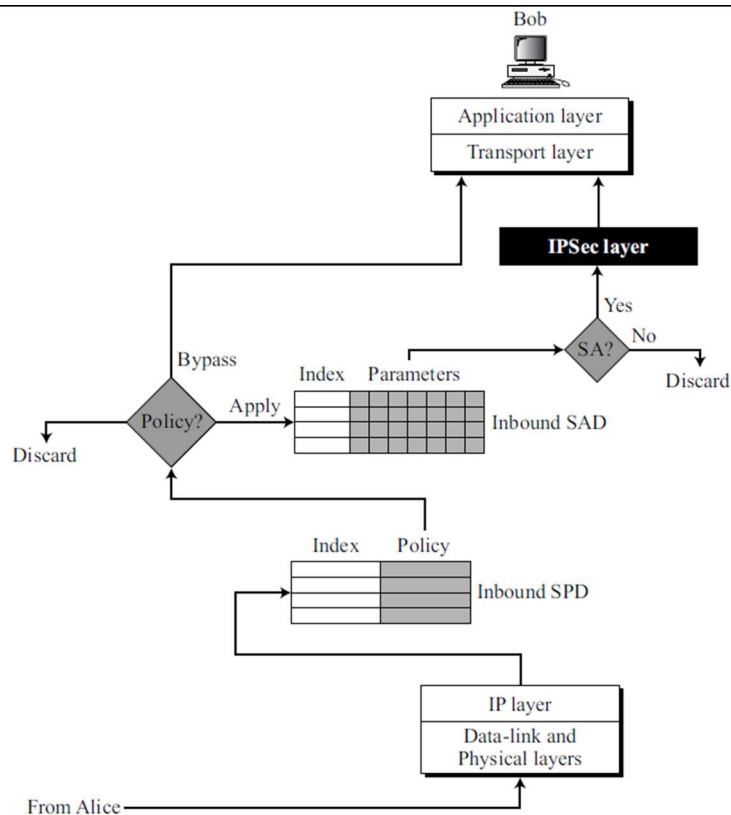


Figure 6.

Answer:

(i)

If an outbound SA is not established yet, the Internet Key Exchange (IKE) protocol is called to create an outbound and inbound SA for this traffic. The outbound SA is added to the outbound SAD by the source; the inbound SA is added to the inbound SAD by the destination.

(ii)

If an inbound SA is already established, the triple SA index is returned that selects the corresponding inbound SA from the inbound SAD. Decryption, authentication, or both are applied. If the packet passes the security criteria, the AH or ESP header is discarded and the packet is delivered to the transport layer.

Question 3e [10 points]

- The IPsec Security Association shown in the following was suggested for IKE Phase-1 negotiation between Habib University's main campus and satellite campus by an internee at IT department. It was rejected by university's network administrator. Briefly explain the reason.

Parameters	R1	R2
Key distribution method	ISAKMP	ISAKMP
Encryption Algorithm	AES	AES
Hash Algorithm	SHA-1	SHA-1
Authentication Method	Pre-shared Keys	Pre-shared Keys
Key Exchange	DH-1	DH-2
IKE SA Lifetime	86400	86400
ISAKMP Key	vpnIPsecEspTunnel	vpnIPsecEspTunnel

- ii. You have been asked by your line manager to suggest typical SA Parameters for Phase-1 negotiation. What will you recommend for Security Association in Phase 1 negotiation for main and satellite campus Routers R1 and R2? Complete the following table with your suggested parameters.

Parameters	R1	R2
Key distribution method		
Encryption Algorithm		
Hash Algorithm		
Authentication Method		
Key Exchange		
IKE SA Lifetime		
ISAKMP Key		

Answer:

(i)

An SA is a relationship between two or more entities that describes how the entities will use security services to communicate securely. IPSec provides many options for performing network encryption and authentication. Each IPSec connection can provide encryption, integrity, authenticity, or all three services. When the security service is determined, the two IPSec peers must determine exactly which algorithms to use (for example, DES or 3DES for encryption; MD5 or SHA-1 for integrity) and both sides should exactly match. Since DH-1 and DH-2 are different in this SA, this SA is INCORRECT.

(ii)

Parameters	R1	R2
Key distribution method	ISAKMP	ISAKMP
Encryption Algorithm	AES	AES
Hash Algorithm	SHA-2	SHA-2
Authentication Method	Pre-shared Keys	Pre-shared Keys
Key Exchange	DH-5	DH-5
IKE SA Lifetime	86400	86400
ISAKMP Key	vpnTunnel	vpnTunnel

Note: Other suitable options are also acceptable.